

FIAP - FACULDADE DE INFORMÁTICA E ADMINISTRAÇÃO PAULISTA

DEFESA CIBERNÉTICA



Vinicius Serafim - RM559144

Igor Silva- RM557730

FIAP x HAKAI

SÃO PAULO

2025

Documentação Técnica - SDK Antifraude para Aplicações Web

1. Introdução

Esta documentação técnica descreve a arquitetura e os principais componentes da Veritas, uma SDK Antifraude desenvolvida pela FIAP x HAKAI, projetada para proteger aplicações *webs*. A SDK visa coletar informações passivas do dispositivo e comportamento do usuário no frontend, enviá-las a um *backend* para avaliação de risco e fornecer uma decisão (*allow*, *review*, *deny*) em tempo real.

2. Visão Geral da Arquitetura

A SDK Antifraude é modular e dividida em três partes principais:

- Frontend: Responsável pela coleta de dados passivos do navegador e do comportamento do usuário.
- Backend: Responsável pela ingestão dos dados, verificação de assinatura, avaliação de risco e tomada de decisão.
- Documentação: Guia de integração e exemplos de uso.

Essa separação permite que a SDK seja facilmente integrada em diversas aplicações *web*, com o frontend sendo um *script* leve e o *backend* um middleware desacoplado.

2.1. Estrutura do Projeto

A estrutura de diretórios do projeto é organizada da seguinte forma:

```
Veritas
├── docs
│   └── README.md
├── examples # Ambiente de teste e exemplificação
│   ├── backend
│   │   ├── package.json
│   │   ├── package-lock.json
│   │   ├── test-commonjs.js
│   │   ├── test-node.js
│   │   └── test-server.js
│   └── frontend
│       └── test-browser.html
├── src/
│   ├── collector.js # módulo coletor
│   ├── crypt.js    # Hashing
│   ├── index.js    # Core da SDK
│   ├── sender.js   # Conector de node
│   └── utils.js    # Utilitários
├── types
│   └── index.d.ts
├── package.json
├── package-lock.json
└── rollup.config.js # configurações de compilação e minificação
```

3. Instalação e Uso

A SDK Veritas pode ser instalada de duas formas principais: via gerenciador de pacotes (*npm* ou *yarn*) ou diretamente via CDN (*Content Delivery Network*).

Via CDN

```
←!— Versão minificada para produção →  
<script src="https://cdn.jsdelivr.net/npm/@veritas/veritas-sdk@1.0.0/dist/veritas-sdk.umd.min.js"></script>  
  
←!— Versão de desenvolvimento →  
<script src="https://cdn.jsdelivr.net/npm/@veritas/veritas-sdk@1.0.0/dist/veritas-sdk.umd.js"></script>
```

Via Package Manager

NPM

```
npm install @veritas/veritas-sdk
```

YARN

```
yarn add @veritas/veritas-sdk
```

Detalhes Adicionais

Utilizamos o Rollup para compilar e minificar o projeto, garantindo um pacote leve e otimizado para uso em aplicações *web*. Isso permite a distribuição tanto via gerenciador de pacotes quanto via CDN, oferecendo flexibilidade na integração.

4. Módulos Principais

A SDK é composta por módulos essenciais, cada um com uma função específica:

- `collector.js`: módulo responsável pela coleta de dados passivos do ambiente do usuário.
- `crypt.js`: contém as funcionalidades de *hashing*, provavelmente para a assinatura HMAC.
- `index.js`: o *core* da SDK, orquestrando as operações dos outros módulos.
- `sender.js`: conector para o ambiente *Node.js*, responsável pelo envio de dados.
- `utils.js`: contém funções utilitárias usadas em outros módulos da SDK.

Funcionalidades da SDK

A SDK Veritas oferece as seguintes características principais:

- Compatibilidade CDN: Pode ser carregado diretamente via CDN.
- Suporte a Múltiplos Formatos: Suporta *ES6*, *CommonJS* (com *require()* e *import*), *UMD*, *ESM*.
- TypeScript: inclui definições de tipos.
- Fingerprinting Avançado: Coleta dados como *Canvas*, *WebGL* e *Audio* para identificação de dispositivos.
- Coleta Comportamental: Monitora movimentos do mouse, eventos de

- teclado, foco e *scroll*.
- **Assinatura HMAC:** Garante a segurança na transmissão de dados.
 - **Coleta Automática:** Recurso configurável e não intrusivo para coleta contínua de dados.

5. Dados Coletados

O SDK coleta passivamente os seguintes tipos de dados:

- **Informações do Navegador:** User Agent, idioma, plataforma, plugins instalados e capacidades do navegador.
- **Informações da Tela:** Resolução, densidade de pixels e orientação da tela.
- **Fingerprinting:** *Hash* único baseado em renderização Canvas, informações da GPU via WebGL e características do contexto de áudio.
- **Comportamento do Usuário:** Movimentos do mouse (coordenadas, não conteúdo), eventos de teclado (teclas, não texto digitado), eventos de foco e scroll, e tempo de permanência.
- **Metadados:** *Timezone* e configurações regionais, capacidades de armazenamento e *Session ID* único.

6. Segurança

A SDK Veritas incorpora diversas funcionalidades de segurança:

- **Assinatura HMAC:** Todos os dados podem ser assinados com HMAC-SHA256 para garantir a integridade e autenticidade.
- **Coleta Passiva:** Não captura conteúdo sensível, como senhas ou textos digitados.
- **Configurável:** Todas as funcionalidades podem ser desabilitadas conforme a necessidade.
- **Timeout e Retry:** Requisições possuem timeout configurável e um sistema de tentativas para maior confiabilidade na transmissão.

7. Configuração

As opções de configuração disponíveis para a SDK são:

- **endpoint**: URL do *backend* (obrigatório).
- **secret**: chave para HMAC (opcional).
- **autoCollect**: habilita/desabilita a coleta automática (padrão: true).
- **collectInterval**: intervalo de coleta em ms (padrão: 30000ms).
- **timeout**: timeout das requisições em *ms* (padrão: 5000ms).
- **retries**: número de tentativas de reenvio (padrão: 2).
- **debug**: habilita logs de *debug* (padrão: false).

8. Métodos Principais

A SDK expõe os seguintes métodos principais:

- **init()**: Inicializa o SDK.
- **collect()**: Coleta dados manualmente.
- **send(data)**: Envia os dados coletados.
- **collectAndSend()**: Combina a coleta e o envio de dados.
- **checkRisk(actionData)**: Verifica o risco de uma ação específica.
- **startAutoCollection()**: Inicia a coleta automática.
- **stopAutoCollection()**: Para a coleta automática.
- **configure(options)**: Reconfigura o SDK.
- **destroy()**: Destroi a instância do SDK.

9. Integração Backend

A SDK Veritas pode ser integrada ao backend para validação e avaliação de risco. Um exemplo de middleware *Node.js/Express* para verificar a assinatura HMAC é fornecido:

Este middleware verifica a assinatura HMAC (***x-sdk-signature***) enviada no cabeçalho da requisição. Se a assinatura for inválida, a requisição é rejeitada com *status* 401. Caso contrário, os dados são processados para avaliação de risco, e uma decisão (*allow*, *review*, *deny*) é retornada com base no *riskScore*.

10. Licença

A [SDK Veritas](#) é distribuída sob a Licença MIT, o que significa que você tem permissão para usar, copiar, modificar e distribuir o software, inclusive para fins comerciais, sem restrições significativas, desde que a notificação de direitos autorais e a isenção de responsabilidade sejam incluídas em todas as cópias ou partes substanciais do software.

Detalhes da Licença MIT:

- Permissão para uso comercial.
- Permissão para modificar.
- Permissão para distribuir.
- Garantia de isenção de responsabilidade e ausência de responsabilidade.

11. Links

Por fim deixaremos os links de acesso ao conteúdo da SDK.

Link para o vídeo de apresentação: <https://youtu.be/3Yv81AnnNWk>

Link para o repositório oficial: <https://github.com/Vinicin1101/veritas>